

1 Avaliação

A avaliação dos projetos será feita segundo uma abordagem funcional, onde cada funcionalidade descrita no enunciado deve ser apresentada pelos alunos. Não serão consideradas funcionalidades incompletas ou valorizada qualquer implementação não funcional. É obrigatório apresentarem os trabalhos em duas máquinas distintas do laboratório (Máquina 1 – **SpertaServer**; Máquina 2 - **SpertaClient**), como apresentado na Figura 1.

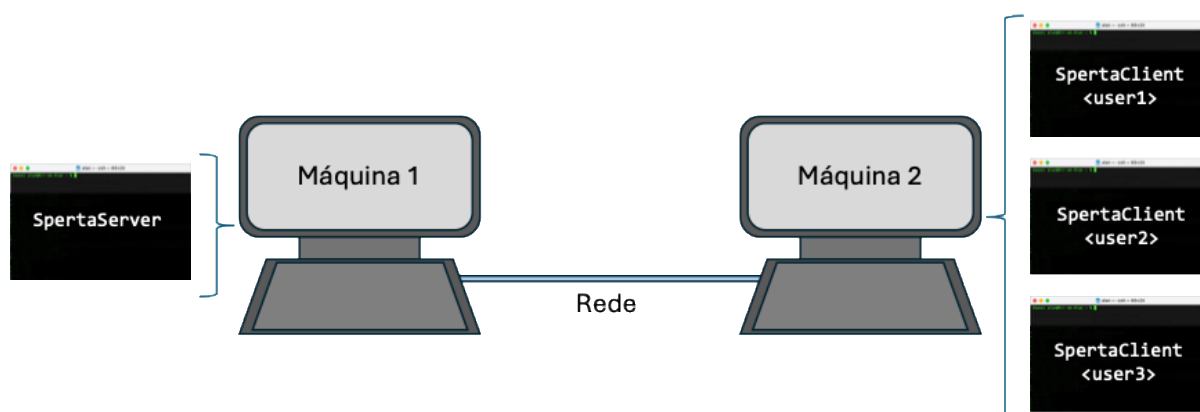


Figura 1 Diagrama de ambiente a criar no laboratório.

De preferência, devem utilizar o sistema operativo Linux.

Cada uma das opções/funcionalidades apresentadas será valorizada de acordo com a seguinte tabela.

Requisito	Verificação	Cotação	
		Máx	Atrib
Comandos da fase 1 funcionais	Preparação (parte 1): Abrir um terminal na máquina 1 e dar partida no SpertaServer Abrir dois terminais na Máquina 2 e correr um cliente em cada terminal. Em cada cliente, autenticar um utilizador diferente: <user1> e <user2>. No terminal do utilizador <user1>, testar: • CREATE • ADD • RD • EC • RT • RH	4,5	
É feita a gestão da concorrência no acesso a estruturas de dados e ficheiros partilhados (e.g., ficheiro de utilizadores e ficheiros com informações de comandos enviados aos dispositivos)	Ver código no servidor	0,5	

Requisito	Verificação	Cotação	
		Máx	Atrib
Keystores + Truststores criadas com chaves/certificados corretos	Usar keytool para ver conteúdo de keystores no servidor e nos clientes, e truststore nos clientes	1	
Utilização de Sockets SSL	Ver código no servidor e no cliente	1,5	
Servidor protege a confidencialidade das passwords dos utilizadores	Ver se o <code>user-id</code> e a <code>password</code> de cada utilizador são guardados no ficheiro de utilizadores no seguinte formato: <user-id>:<hash(password + salt)>:<salt>	1	
Autenticação de clientes	Ver no código se o Servidor autentica o utilizador por meio da verificação da síntese de (password + salt) guardada no ficheiro de utilizadores.	0,5	
Servidor cifra os ficheiros com informações das casas e os dados para atestação remota da aplicação cliente com PBE/AES128	Ver conteúdo dos ficheiros (deve estar cifrado) e ver geração de chave AES baseada na password	1	
Servidor verifica integridade dos ficheiros mantidos pelo servidor (e.g., ficheiro de utilizadores e ficheiros contendo informações das casas, secções e dispositivos)	Verificar: 1) se é guardado o <i>hash</i> de cada ficheiro (e atualizado em qualquer alteração de conteúdo) 2) se o <i>hash</i> é verificado a cada acesso de leitura aos ficheiros mantidos pelo servidor 3) se o servidor imprime um aviso e termina quando qualquer destes ficheiros está corrompido (corromper o ficheiro manualmente ou substituí-lo por outro ficheiro para teste)	1	
Atestação remota da aplicação (deve ocorrer antes da autenticação do utilizador)	Verificar se o servidor envia o <i>nonce</i> para a aplicação cliente.	0,5	
	Ver no código se o cliente concatena o <i>nonce</i> com o ficheiro executável SpertaClient , calcula o hash SHA256 desta concatenação e envia o hash obtido ao servidor.	0,5	
	Testar o mecanismo de atestação remota: - Caso 1: servidor tem como referência uma cópia válida da aplicação SpertaClient. - Caso 2: servidor tem como referência uma versão modificada da aplicação SpertaClient (ou outro ficheiro qualquer).	0,5	
Verificação do funcionamento do SpertaServer como servidos de certificados de chaves públicas.	Preparação (parte 2): Verificar que no servidor <u>só há dois certificados</u> (ficheiros no formato cert). Abrir um novo terminal Máquina 2 e correr o terceiro cliente. Neste cliente, autenticar o terceiro utilizador <user3>.		
	Verificar se o servidor possui <u>três certificados</u> (ficheiros no formato cert), ou seja, inclui agora o certificado do <user3>.	0,5	
	Verificar se a truststore do utilizador <user1> não possui o certificado do <user3>. No terminal do utilizador <user1>, executar o comando: - CREATE c1 No terminal do utilizador <user1>, fazer o comando: - ADD user3 c1 M Verificar se agora a truststore do utilizador <user1> possui também o certificado do <user3>.	0,5	

Requisito	Verificação	Cotação	
		Máx	Atrib
Confidencialidade fim-a-fim para informações de comandos enviados para dispositivos (ligar, desligar e ligar com temporização)	Preparação (parte 3): Nos testes abaixo devem usar os mesmos terminais que já estarão abertos na Máquina 2 (ver Preparação partes 1 e 2, acima). Cada terminal terá uma aplicação cliente em execução com um utilizador diferente autenticado.		
	Geração das Chaves da Secção: Verificar no código do cliente a geração das chaves das secções, bem como a sua encriptação com a chave pública do owner. Terminal do utilizador 1: CREATE c2 Verificar se, com este comando, foram guardadas no servidor seis chaves encriptadas com o nome <code>key.c2.<s>.user1</code> , uma para cada secção <s> da casa c2.	0,5	
	Partilha das Chaves da Secção: Terminal do utilizador 1: - ADD user2 c2 P - ADD user3 c2 P Verificar se, com estes comandos, foram guardadas no servidor duas cópias cifradas da Chave da Secção P da casa c2 (uma para cada utilizador <user2> e <user3>), com nomes: <code>key.c2.P.user2</code> , e <code>key.c2.P.user3</code>	1	
	Envio de comandos cifrados aos dispositivos: No Terminal do utilizador 1: - RD c2 P No Terminal do utilizador 2: - EC c2 P1 5 Verificar se o utilizador 2 recebe a Chave da Secção da secção P cifrada com a sua chave pública. Verificar no código do cliente se este envia ao servidor o valor <int> dos comandos EC <hm> <d> <int> cifrado com a Chave da Secção . Verificar se o servidor recebe e guarda o valor <int> cifrado com a Chave da Secção .	1	
	Obtenção de informações cifradas de comandos aos dispositivos: Verificar no código do cliente a receção e a decifra da Chave da Secção , assim como a receção e a decifra das informações recebidas. No Terminal do utilizador 1: - RD c2 M - EC c2 M1 1 No terminal do utilizador 3: - RH c2 P1 - RH c2 M1 - RT c2 Confirmar se: 1) No comando RH c2 P1 foi recebido e apresentado em texto claro o histórico de comandos (ficheiro de log .csv) enviados ao dispositivo P1.	1	

Requisito	Verificação	Cotação	
		Máx	Atrib
	2) No comando <code>RH c2 M1</code> o utilizador recebeu <code>NOPerm</code> . 3) No comando <code>RT c2</code> recebe e apresenta em texto claro apenas a informação do dispositivo pertencente à secção a qual tem permissões (ou seja, apenas de <code>P1</code>). Não devem ser apresentadas informações de <code>M1</code> , visto que o utilizador 3 não tem permissões na secção <code>M</code> .		
Impressão geral sobre organização e legibilidade do código, bem como funcionamento do sistema	Ver código no cliente e no servidor.	1	
Preparação e qualidade da discussão	• O grupo preparou a apresentação do seu projeto com cuidado, executando os <code>.jar</code> submetidos em terminais separados para o servidor (na Máquina 1) e para cada cliente (na Máquina 2) • Todos os elementos do grupo responderam às questões colocadas sem hesitações, demonstrando conhecimento do código submetido • A demonstração do projeto decorreu sem quaisquer incidentes e dentro do tempo	2	